

Attleborough Primary School, Audit Report**Audit Date: 13 February 2020****Report: Year 2 visit 3****DPE: Linda Mortimer****School members****Headteacher: Gayle Long****Business Manager: Susie Willingham**

1. Visit details

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 6 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 5.1 below).

Review actions recommended at time of previous visit – 3.10.19

All recommendations made during previous visit have been actioned and the following is noted:

Photos of students in the staffroom: These remain in place, but student names or any related medical details are not evident.

ICO Registration: School to register with ICO as soon as possible.

GDPR Policy: Please note Data Protection Education as the DPO.

Privacy Notice: The school's Privacy Notice is currently based on the DfE model document. Please ensure that Data Protection Education is noted as the DPO.

The school's Privacy Notice should also include a more detailed list of third parties with whom they share PII data, this can be included in a separate appendix to the main Notice.

School to direct visitors to location of Privacy Notice ie that it can be found on the school's website.

Best Practice Checklists: Were reviewed at the time of the visit. The school will concentrate on completing the checklists.

GDPR Training: All Leadership Team and senior staff have completed GDPR 101 training with the exception of the Deputy Headteacher who is unable to complete this training due to technical difficulties. These problems have been reported to DPE and the school awaits access.

Policies: All policies recommended at time of visit for adoption by the school will be ratified by Governing Body and where appropriate, will be published on the school website. These are; Records Management, Information Classification, Clear Desk and Screen, Working away from School.

Consent: The school has checked their consent form with the DPE standard consent form.

Retention Schedule: The school is clear on retention schedules and refers to the IRMS Toolkit for guidance.

CCTV: The school has adopted the relevant policies and procedures for CCTV. They also use the DPE model log book for recording third parties requiring access to recordings. The school confirms that there is now appropriate CCTV signage in place.

Audit walk and findings on 13.2.20

SEND Record Management: All SEND paperwork is scanned and attached to student records on Pupil Asset, therefore limiting access to personal/confidential data.

Management of Student Assessment: The school makes full use of the cloud based PIXL Assessment module, which means that no hard copies of assessments are generated. This limits access to personal/confidential data.

Management of Communication with Parent: The school uses Pupil Asset to manage online payments, as well as providing communication to parents via text and email.

Publication Scheme: This was discussed and examples will be provided for the school to make reference to. More guidance can be found under the News tab on the Knowledge Bank.

Staff Training: All staff should complete GDPR 101. Staff completion can be checked on the Dashboard in Knowledge Bank – go to Reports/Select Reports/Course Enrolment. A GDPR 20-minute refresher course will be available shortly on Knowledge Bank. DPE recommend that staff should refresh their training every 2 years.

Naming convention: All exercise books, work trays, files, displays and coat pegs use first names only.

Laptops: Are encrypted, password protected and accounted for on a regular basis.

Action: School to share the Working Away from School Policy with all staff who work at home. This can be managed via Compliance Manager on Knowledge Bank.

Server: Is situated in a dedicated locked room. JC Commtech have procedures for regular cleansing.

School Kitchen: Operated by Norse. All allergy information is kept securely.

Staffroom: Staff pigeonholes were checked and no paperwork / documents were found that included any PII data.

First Aid Records: Records are stored securely.

Medical Student Care Plans: Are stored securely in student files kept in a locked cabinet.

GDPRs Record Keeping: The school has used GDPRs for recording /logging of SARs, Breaches, FOIs. They will now move to using DPE Knowledge Bank in order to keep all records in one central place.

2. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>